

Software Requirements Specification

Digital Health Record Management System

Version 1.0 | Date: 2026-09-10 | Status: MVP specification

Digital Health Record Management System

Version: 1.0

Date: 2026-09-10

Status: MVP specification

1. Introduction

1.1 Purpose

This document specifies the requirements for a clinical information management and summarization system. The system consolidates patient health records into a chronological, searchable, evidence-backed view and provides AI-assisted summaries for clinical review.

The system is an information-assistance tool. It does not diagnose disease, prescribe treatment, change medication dosage, or make final clinical decisions.

1.2 Scope

The system will support:

- user registration, login, session restoration, and logout;
- role-based access for patients, doctors, and administrators;
- patient profiles and doctor-patient access management;
- structured medical records, including encounters, conditions, medications, allergies, and observations;
- private upload, storage, retrieval, and deletion of PDF and image reports;
- text extraction and OCR for supported reports;
- normalization of supported laboratory observations;
- chronological patient timelines;
- deterministic trend and conflict detection;
- structured AI summaries with source evidence identifiers;
- audit logging for sensitive operations;
- responsive web access through a React frontend and REST API.

1.3 Intended audience

This specification is intended for product owners, developers, testers, security reviewers, clinical subject-matter reviewers, and deployment operators.

1.4 Definitions

Term	Definition
Patient	A person whose health records are managed by the system.
Doctor	An authorized clinical user who reviews patient information.
Administrator	A user who manages access, users, configuration, and audit review.
Observation	A structured clinical or laboratory value with date, unit, status, and provenance.
Evidence ID	An identifier linking a statement, trend, conflict, or summary item to source records.
AI summary	A structured, generated overview of existing records for clinician review.
Patient scope	The set of records a user is authorized to access for one patient.

2. Product Overview

2.1 Problem statement

Patient information is often fragmented across consultations, diagnoses, medications, allergies, prescriptions, laboratory reports, and uploaded documents. Doctors need a single longitudinal view that reduces manual searching while preserving source evidence and uncertainty.

2.2 Product goals

1. Provide one patient-scoped view of relevant health records.
2. Reduce the time required to find recent and historically relevant information.
3. Make trends, contradictions, missing data, and source documents visible.
4. Keep all clinical decisions with the responsible doctor.

5. Preserve patient isolation, privacy, and auditability.
6. Keep core record access useful when the AI provider is unavailable.

2.3 Product principles

- **Doctor in the loop:** generated content supports review and is not a medical decision.
- **Evidence first:** important generated statements cite source records.
- **Missing is not normal:** absent values must not be represented as normal values.
- **Patient isolation:** authorization is enforced for every patient-scoped operation.
- **Core EHR independence:** records and reports remain available without AI generation.
- **Minimal AI context:** only the context needed for a requested summary is sent to the provider.
- **Auditability:** sensitive access and changes are traceable.
- **Synthetic development data:** development and test data must not identify real patients.

2.4 User classes

Doctor

A doctor can access assigned patients, review and update authorized records, upload and view reports, review timelines and trends, and generate AI summaries.

Patient

A patient can access their own profile and records, upload documents, view reports and medications, and view summaries when the product permissions allow it.

Administrator

An administrator can manage users and doctor-patient access, review audit logs, and manage limited system configuration. Administrative capabilities are intentionally limited in the MVP.

3. System Context and Architecture

3.1 System context

The browser communicates with the application API over HTTPS. The API owns authentication, authorization, validation, business rules, document processing, AI-provider access, persistence, and audit logging.

Browser

- > React/Vite frontend
- > Express/Node.js REST API
- > MongoDB
- > private document storage
- > optional OCR/PDF extraction
- > server-side AI provider

The browser must never receive database credentials, JWT signing secrets, storage secrets, or AI-provider keys.

3.2 Technology constraints

- TypeScript across frontend, backend, and shared types.
- React and Vite for the frontend.
- Express and Node.js for the backend.
- MongoDB with Mongoose for persistence.
- REST and JSON for API communication.
- TanStack Query for frontend server state.
- Zod for runtime validation.
- JWT access tokens with secure refresh-token cookies.
- Local private storage for development and an S3-compatible abstraction for deployment.
- Vitest and Supertest for automated tests; Playwright for critical browser flows.

3.3 Deployment environments

The system shall support:

- local development with Docker MongoDB and local document storage;
- test execution with isolated synthetic data;
- deployment using a managed MongoDB-compatible database, private object storage, and configured AI provider.

4. Functional Requirements

4.1 Authentication and sessions

- **FR-AUTH-001:** The system shall allow a user to register with name, email, password, and an allowed public role.
- **FR-AUTH-002:** Public registration shall accept only patient or doctor; administrator accounts shall require controlled provisioning.
- **FR-AUTH-003:** The system shall hash passwords using a password-hashing algorithm such as bcrypt and shall never store plaintext passwords.
- **FR-AUTH-004:** The system shall authenticate users with email, password, and an explicit selected role.
- **FR-AUTH-005:** The system shall reject login when the selected role does not match the stored account role.
- **FR-AUTH-006:** The system shall issue a short-lived access token and a refresh token through a secure, httpOnly cookie.
- **FR-AUTH-007:** The client shall keep the access token in memory and shall not store long-lived authentication tokens in localStorage.
- **FR-AUTH-008:** The system shall restore a valid session after browser reload through the refresh endpoint.
- **FR-AUTH-009:** The system shall support logout and invalidate or remove the active refresh session according to the configured session policy.
- **FR-AUTH-010:** Protected API routes shall reject missing, malformed, expired, or invalid credentials.
- **FR-AUTH-011:** Authentication endpoints shall be rate-limited and shall return sanitized errors.

4.2 Authorization and patient access

- **FR-ACCESS-001:** Every protected operation shall identify the authenticated actor and effective role.
- **FR-ACCESS-002:** Doctors shall access only patients for whom they have active access.
- **FR-ACCESS-003:** Patients shall access only their own patient record.
- **FR-ACCESS-004:** Administrators shall have the access explicitly assigned by the authorization policy.
- **FR-ACCESS-005:** Unauthorized cross-patient reads, writes, uploads, downloads, and summary requests shall return a forbidden response.
- **FR-ACCESS-006:** Patient-scoped queries and mutations shall include the patient identifier in the authorization and persistence boundary.
- **FR-ACCESS-007:** Sensitive successful operations shall create an audit event containing actor, action, resource, patient where applicable, and request identifier.

4.3 Patient management

- **FR-PAT-001:** Authorized doctors shall create patient profiles.
- **FR-PAT-002:** Authorized users shall list patients within their permitted scope.
- **FR-PAT-003:** The patient list shall support search or filtering appropriate to the available patient fields.
- **FR-PAT-004:** Authorized users shall view a patient profile.
- **FR-PAT-005:** Authorized users shall update permitted patient profile fields.
- **FR-PAT-006:** Patient creation and updates shall be validated at the API boundary.
- **FR-PAT-007:** Patient creation, viewing, and updating shall be auditable.

4.4 Structured medical records

- **FR-REC-001:** Authorized users shall view a patient's encounters, conditions, medications, allergies, and observations.
- **FR-REC-002:** Authorized doctors and administrators shall create, update, and delete permitted clinical records.
- **FR-REC-003:** Patients shall not modify clinician-managed records unless a specific policy permits the operation.
- **FR-REC-004:** Each record shall retain its patient ownership and relevant clinical date.
- **FR-REC-005:** Medication records shall support current and historical status where applicable.
- **FR-REC-006:** Condition records shall support status and source information where applicable.
- **FR-REC-007:** Allergy records shall distinguish active, inactive, and uncertain states where supported.
- **FR-REC-008:** Observation records shall retain value, unit, observation date, status, and provenance.
- **FR-REC-009:** Records with missing information shall preserve the missing or unknown state and shall not infer normality.
- **FR-REC-010:** Invalid dates, unsupported statuses, malformed values, and invalid patient references shall be rejected.

4.5 Reports and documents

- **FR-REPORT-001:** Authorized users shall upload one supported PDF, PNG, or JPEG report at a time.
- **FR-REPORT-002:** The system shall enforce the configured maximum file size.
- **FR-REPORT-003:** The system shall reject unsupported file types, duplicate files, malformed uploads, and unauthorized uploads.
- **FR-REPORT-004:** Uploaded files shall be stored privately under a generated storage key rather than a user-controlled path.
- **FR-REPORT-005:** The database shall store report metadata and storage references, not unbounded binary file contents.
- **FR-REPORT-006:** Authorized users shall list report metadata and processing status for a patient.

- **FR-REPORT-007:** Authorized users shall download a private report only after an access check.
- **FR-REPORT-008:** Authorized users shall delete reports according to the configured deletion policy.
- **FR-REPORT-009:** The system shall expose processing states such as uploaded, processing, processed, and failed.
- **FR-REPORT-010:** Report access, upload, and deletion shall be auditable without storing document contents in the audit record.

4.6 Extraction and normalization

- **FR-EXTRACT-001:** The system shall extract text from supported text-based PDF reports.
- **FR-EXTRACT-002:** The system shall use OCR for supported image reports when configured and available.
- **FR-EXTRACT-003:** The system shall persist extraction status and an extraction failure reason when processing fails.
- **FR-EXTRACT-004:** The system shall create structured observations only for values directly recognized by supported normalization rules.
- **FR-EXTRACT-005:** Extracted observations shall be marked as extracted and linked to their source report.
- **FR-EXTRACT-006:** The system shall not convert an unreadable or missing value into a normal value.
- **FR-EXTRACT-007:** Users shall be able to distinguish extracted data from manually verified or manually entered data.

4.7 Timeline, trends, and conflicts

- **FR-TIMELINE-001:** The system shall combine relevant patient records and reports into a chronological timeline.
- **FR-TIMELINE-002:** Timeline events shall be sorted using clinical dates and shall retain source identifiers.
- **FR-TIMELINE-003:** The system shall calculate trends only from compatible observations, including compatible units.
- **FR-TIMELINE-004:** A trend shall require sufficient observations according to the configured rule; the MVP minimum is two compatible observations.
- **FR-TIMELINE-005:** The system shall classify supported changes as increasing, decreasing, stable, fluctuating, or insufficient.
- **FR-TIMELINE-006:** The system shall detect supported conflicts, including contradictory statuses and exact duplicate observations.
- **FR-TIMELINE-007:** Trend and conflict results shall include evidence identifiers.
- **FR-TIMELINE-008:** The system shall present uncertainty and insufficient data explicitly.

4.8 AI-assisted summaries

- **FR-AI-001:** Authorized doctors and administrators shall be able to request a patient summary.
- **FR-AI-002:** The server shall construct AI context from authorized, relevant patient records, timeline events, trends, conflicts, and evidence identifiers.
- **FR-AI-003:** The server shall not send unauthorized patient data or unnecessary fields to the AI provider.
- **FR-AI-004:** The AI provider shall be accessed only by the backend service.
- **FR-AI-005:** The summary shall use a structured schema rather than unrestricted text as the primary persisted output.
- **FR-AI-006:** Every factual summary item shall cite one or more available evidence identifiers.
- **FR-AI-007:** The system shall clearly label generated content as requiring clinician review.
- **FR-AI-008:** The summary shall distinguish documented information, missing information, uncertainty, trends, and conflicts.
- **FR-AI-009:** The AI shall not prescribe medication, change dosage, diagnose disease, or issue a definitive treatment decision.
- **FR-AI-010:** Invalid provider output, missing evidence, provider failure, and timeout shall be persisted or reported as a failed generation with a sanitized error.
- **FR-AI-011:** The core patient record, reports, and deterministic timeline shall remain usable when the AI provider is unavailable.
- **FR-AI-012:** Authorized users shall be able to view previous summaries and their generation status according to retention policy.

4.9 Administration and audit

- **FR-ADMIN-001:** Administrators shall be able to manage users and doctor-patient access within the permitted administrative scope.
- **FR-ADMIN-002:** Administrators shall be able to review audit events.
- **FR-ADMIN-003:** Audit events shall include actor, action, target resource, patient scope when applicable, timestamp, and request identifier.
- **FR-ADMIN-004:** Audit events shall not contain passwords, access tokens, document contents, or complete request bodies.
- **FR-ADMIN-005:** Audit recording failure shall not expose sensitive data or leak implementation details to the client.

4.10 Frontend navigation and usability

- **FR-UI-001:** The frontend shall provide routes for login, registration, dashboard, patients, patient overview, timeline, reports, medications, AI summaries, report upload, profile, and not-found handling.
- **FR-UI-002:** Protected routes shall redirect unauthenticated users to login.
- **FR-UI-003:** Navigation and available actions shall reflect the authenticated user's role.

- **FR-UI-004:** Forms shall provide validation, loading, success, empty, and error states.
- **FR-UI-005:** The interface shall display report processing, AI provider unavailable, and clinician-review states clearly.
- **FR-UI-006:** The interface shall be usable on desktop and mobile viewport sizes.
- **FR-UI-007:** Server state shall be fetched and cached through the configured query client rather than duplicated in client-only state.

5. External Interface Requirements

5.1 REST API

The API shall be rooted at `/api` and use JSON for ordinary requests and responses.

Core resources include:

```
GET    /api/health
POST   /api/auth/register
POST   /api/auth/login
POST   /api/auth/refresh
POST   /api/auth/logout
GET    /api/auth/me

GET    /api/patients
POST   /api/patients
GET    /api/patients/:patientId
PATCH /api/patients/:patientId

GET    /api/patients/:patientId/timeline
GET    /api/patients/:patientId/conditions
GET    /api/patients/:patientId/medications
GET    /api/patients/:patientId/allergies
GET    /api/patients/:patientId/observations

POST   /api/patients/:patientId/reports
GET    /api/patients/:patientId/reports
GET    /api/patients/:patientId/reports/:reportId
DELETE /api/patients/:patientId/reports/:reportId

POST   /api/patients/:patientId/ai-summaries
GET    /api/patients/:patientId/ai-summaries
```

The API shall use appropriate HTTP status codes, validate input, return stable error shapes, and avoid exposing stack traces or sensitive implementation details.

5.2 File upload interface

Report uploads shall use multipart form data. The server shall validate both declared metadata and actual supported file characteristics where practical.

5.3 Storage interface

The document service shall use a storage abstraction with:

- put object;
- read object;
- delete object;
- generated private key;
- no public unauthenticated URL requirement.

Local filesystem storage is for development. Production shall use private object storage.

5.4 AI provider interface

The AI service abstraction shall accept validated minimal context and return a validated structured summary. Provider credentials and provider-specific request details shall remain server-side.

6. Data Requirements

6.1 Core entities

The system shall support at least the following entities:

- User
- Patient
- DoctorPatientAccess
- Encounter
- Condition
- Medication
- Allergy

- Observation
- MedicalReport
- Document
- AISummary
- AuditLog

6.2 Data integrity

- Every patient-scoped entity shall contain a patient ownership reference.
- References to deleted or inaccessible resources shall not bypass authorization.
- Timestamps shall be stored consistently and returned in an unambiguous format.
- Clinical dates and record creation dates shall remain distinguishable.
- Observation units shall be retained and used when determining compatibility.
- Source report and evidence references shall remain resolvable while the source is retained.

6.3 Privacy and retention

- Real patient-identifying data shall not be used in development or test fixtures.
- Uploaded documents shall not be committed to source control.
- Secrets shall be supplied through environment configuration.
- Production retention and deletion periods shall be configured by the deployment owner and applicable policy.

7. Non-Functional Requirements

7.1 Security

- **NFR-SEC-001:** All production traffic shall use HTTPS.
- **NFR-SEC-002:** Refresh cookies shall be secure, httpOnly, and configured with an appropriate SameSite policy.
- **NFR-SEC-003:** The API shall use secure response headers and credentialed, allowlisted CORS.
- **NFR-SEC-004:** Authentication and sensitive endpoints shall be rate-limited as appropriate.
- **NFR-SEC-005:** Authorization shall be enforced server-side and shall not depend on frontend visibility.
- **NFR-SEC-006:** Logs and audit records shall avoid passwords, tokens, document contents, and unnecessary patient-identifying data.
- **NFR-SEC-007:** Uploaded files shall remain private and shall not be served as unrestricted static assets.

7.2 Privacy and compliance readiness

The MVP shall provide technical controls that support privacy review, including access isolation, private storage, auditability, source traceability, and configurable retention. Formal regulatory certification or legal compliance is outside this specification and requires deployment-specific assessment.

7.3 Performance

- **NFR-PERF-001:** Health and ordinary authenticated API requests should return promptly under expected MVP load.
- **NFR-PERF-002:** Large or CPU-intensive extraction work shall not block unrelated API requests where asynchronous processing is available.
- **NFR-PERF-003:** Patient-scoped queries shall use appropriate indexes.
- **NFR-PERF-004:** The frontend shall show loading states instead of appearing unresponsive during network operations.

7.4 Reliability and availability

- **NFR-REL-001:** A failed AI provider request shall not make stored records inaccessible.
- **NFR-REL-002:** Failed report extraction shall preserve the report and expose a failed status.
- **NFR-REL-003:** Errors shall be handled consistently through backend error middleware and user-safe frontend messages.
- **NFR-REL-004:** Audit failures shall be observable to operators without exposing sensitive details to users.

7.5 Maintainability

- **NFR-MAINT-001:** Business rules shall remain in backend services and repositories rather than route handlers or JSX.
- **NFR-MAINT-002:** Shared request and response types shall be defined in the shared package where appropriate.
- **NFR-MAINT-003:** The system shall use ESLint, Prettier, and TypeScript checks in the standard project commands.
- **NFR-MAINT-004:** New clinical rules shall be covered by focused unit or integration tests.

7.6 Accessibility and compatibility

- **NFR-UX-001:** Interactive controls shall have accessible names and visible states.

- **NFR-UX-002:** Forms and error messages shall be keyboard accessible.
- **NFR-UX-003:** The application shall support current stable desktop browsers and responsive mobile layouts supported by the frontend baseline.

8. Safety and Clinical Boundaries

The following are mandatory product constraints:

1. The system shall present AI output as assistance for clinician review.
2. The system shall not represent missing data as normal data.
3. The system shall preserve source evidence for important statements.
4. The system shall show uncertainty, extraction failures, and insufficient observations.
5. The system shall not independently diagnose, prescribe, modify treatment, or make final clinical decisions.
6. A doctor remains responsible for interpreting records and making clinical decisions.

9. Acceptance Criteria

The MVP is acceptable when all of the following are true:

- A user can register, log in with the selected role, refresh a session, and log out.
- An unauthenticated user cannot access protected routes or APIs.
- A doctor cannot read or modify another doctor's unauthorized patient records.
- A patient cannot access another patient's records.
- Authorized users can create, view, and update permitted patient and medical-record data.
- Authorized users can upload, list, download, process, and delete supported private reports.
- Unsupported, oversized, duplicate, and unauthorized uploads are rejected.
- Extracted observations retain source links and extraction status.
- The patient timeline is chronological and includes supported trends and conflicts with evidence IDs.
- AI summaries contain structured output, evidence references, clinician-review labeling, and safe failure states.
- The patient record remains available when AI generation fails or is unavailable.
- Sensitive operations create auditable events without storing document contents or secrets.
- Automated lint, format, build, and test checks pass for the repository.

10. Out of Scope

The following are not part of the MVP unless separately approved:

- autonomous diagnosis or treatment recommendations;
- medication prescribing, dosage changes, or refill authorization;
- billing, payments, insurance claims, or revenue-cycle management;
- telemedicine video or chat;
- pharmacy integration;
- external hospital or laboratory integrations;
- broad medical coding or terminology coverage beyond implemented normalization rules;
- unrestricted patient self-registration as an administrator;
- public document URLs;
- formal regulatory certification;
- production-grade clinical decision support validation;
- advanced predictive models or risk scoring;
- email, SMS, and push notification infrastructure.

11. Traceability to Current Implementation

The repository currently contains implemented flows for the Phase 1-10 MVP boundary, including:

- frontend/backend health check;
- application shell and route map;
- authentication and session restoration;

- patient management and access checks;
- structured medical records;
- private report upload and retrieval;
- PDF/image extraction and observation normalization;
- deterministic timelines, trends, and conflicts;
- structured AI summaries with evidence validation;
- request IDs, security headers, rate limiting, and audit logging.

The authoritative runtime paths are documented in `flow.md`, while implementation sequencing and future phase boundaries are documented in `plan.md`.

12. Open Decisions for Production

The following decisions require deployment-specific confirmation before handling real patient data:

- applicable legal and regulatory obligations;
- production identity verification and doctor credentialing;
- refresh-token revocation and session administration policy;
- object-storage provider, encryption, backup, and retention policy;
- OCR and extraction quality thresholds plus human verification workflow;
- AI provider data-processing agreement, model choice, retention behavior, and evaluation process;
- operational monitoring, incident response, and audit-log retention;
- supported browser versions and service-level objectives.